Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a análise defensiva de arquivo é permitida

Vou começar lendo as instruções de como tratar arquivos enviados e depois farei uma análise **estática** (sem executar o arquivo em nenhum momento).

Ran 6 commands, read a file

Fiz uma análise **estática**: o arquivo nunca foi executado nem importado. O veredito está no final, como você pediu.

Etapa 1: triagem. O `exec.pyc` tem 12.336 bytes e é bytecode de **Python 3.13**, compilado de um script de cerca de 7,9 KB em 02/10/2026, ou seja, uma amostra recente. O nome interno do script-fonte é uma sequência hexadecimal de 64 caracteres, comum em amostras catalogadas automaticamente. Isso, sozinho, não prova nada.

Etapa 2: estrutura. Não há decompilador para 3.13 no ambiente, então escrevi um leitor próprio do formato `marshal`. O arquivo tem 10 funções, entre elas `fechar_chrome`, `notificar_instalacao`, `download_and_extract_extension`, `add_extension`, `calculateHMAC` e `calc_supermac`. Não há ofuscação nem texto cifrado, então a leitura é confiável. Pela estrutura, ao ser executado como script ele chama `add_extension()` automaticamente.

Etapa 3: o que o código faz.

1. **Mata o Chrome.** `fechar_chrome` encerra todos os processos do navegador para poder editar seus arquivos.
2. **Baixa um payload.** `add_extension` obtém o usuário e o SID do Windows, baixa um ZIP de um servidor externo e o extrai numa pasta temporária.
3. **Instala a extensão à força.** O código escreve manualmente uma entrada no arquivo `...\Chrome\User Data\Default\Secure Preferences`. A extensão fica marcada como "não da Web Store" e recebe acesso a `cookies`, `tabs`, `scripting`, `downloads` e `storage` em **todos os sites**, inclusive no modo anônimo. Também liga o modo desenvolvedor sem avisar.
4. **Falsifica a proteção do Chrome.** As funções de HMAC recalculam os códigos de integridade que o Chrome usa para detectar adulteração, com o SID do usuário e

uma chave fixa de 64 bytes embutida. Assim o Chrome aceita a extensão como legítima, sem alertar nem remover.

5. **Avisa o atacante.** `notificar_instalacao` envia ao tópico público do ntfy.sh a mensagem "Extensão `<ID>` instalada para o usuário `<nome>`". O nome do tópico ("...caiunoob", gíria para "caiu, noob") é um deboche.

Etapa 4: avaliação. Nada disso tem uso legítimo. Extensões legítimas vêm da Chrome Web Store ou de política corporativa, e ninguém precisa matar o Chrome, forjar assinaturas de integridade e notificar um canal externo a cada instalação. Não vi persistência adicional (registro, tarefa agendada), porque o código depende da própria extensão. Eu não tenho o ZIP baixado, então não sei exatamente o que a extensão faz, mas esse conjunto de permissões é típico de roubo de cookies e sessões e de injeção em páginas.

Veredito: é malware (confiança alta)

É um instalador de extensão maliciosa para o Chrome no Windows, que adultera o `Secure Preferences` (MITRE ATT&CK T1176).

Indicadores (IOCs):

- SHA-256: `0e2d54cf86bb9d0d0cd02ed601be2df15a79d9a4927c82af61e0b0f666bc5941`
- MD5: `5ab47e07f32c9170bf6c4d500b096f3d`
- `hxxps://antiddos-protection[.]net/___________/chrome_extension.zip`
- `hxxps://ntfy[.]sh/crimeorganizado000000000000caiunoob`
- Vestígios: pasta `chrome_extension` e arquivo `chrome_extension.zip` dentro de `%TEMP%\tmp*`

O que fazer:

- **Se você não executou o arquivo,** não execute, apague-o e, se quiser, consulte o hash no VirusTotal (aqui eu não tinha rede para isso).
- **Se executou,** abra `chrome://extensions` e remova qualquer extensão desconhecida, verificando se o modo desenvolvedor foi ligado sem você. Rode um antivírus completo. Como cookies de sessão podem ter sido expostos, troque as senhas importantes a partir de **outro dispositivo limpo**, encerre as sessões ativas, ative a verificação em duas etapas e confira movimentações bancárias.

Qual é a categoria principal deste malware?

Descartando outras categorias de malware ▸

A categoria principal é **Trojan do tipo dropper/downloader**, mais especificamente um *instalador de extensão maliciosa de navegador* (*browser extension sideloader*).

O script não faz o roubo de dados por conta própria. Ele baixa um componente externo (o ZIP da extensão), o instala à força no Chrome adulterando o `Secure Preferences` e avisa o atacante. O papel dele é entregar e esconder o payload. Pelo método, também poderia ser chamado de *browser hijacker*, mas a função dominante é a de dropper.

Ele não se encaixa em outras categorias:

- **Vírus ou worm:** não se replica nem se espalha.
- **Ransomware:** não cifra nem apaga arquivos.
- **RAT ou backdoor:** o próprio script não tem controle remoto. Se houver, estaria na extensão.

O objetivo final provável é **infostealer**, ou seja, roubo de cookies e sessões, ou injeção em páginas como as de bancos. Isso é uma inferência, porque a extensão pede acesso a cookies, abas e scripts em todos os sites. Para confirmar, seria preciso analisar o ZIP baixado, que não estava no arquivo enviado.